

Activité 1 : Durcissement des OS – yummyrecipesforme.com

Statut : Résolu ✨ | **Analyste :** Emily | **Date :** 12 Juin 2026

Ce document formalise l'investigation menée sur l'infrastructure web de l'entreprise suite à une compromission de privilèges et à une redirection malveillante de trafic.

01. Protocoles Réseau Identifiés

Lors de l'analyse des traces réseau au sein de l'environnement contrôlé (sandbox) et du décodage du journal *tcpdump*, les protocoles de la couche Application du modèle TCP/IP suivants ont été isolés :

DNS (Port 53)

HTTP (Port 80)

- **DNS (Domain Name System) :** Utilisé en amont pour la résolution des noms de domaine. On observe une première requête légitime pointant vers l'IP réelle du site, puis une seconde requête altérée redirigeant le flux vers l'adresse IP de l'infrastructure pirate.
- **HTTP (Hypertext Transfer Protocol) :** Utilisé pour le transfert des fichiers en clair. C'est via ce protocole non sécurisé que le script malveillant de la page d'accueil a poussé le téléchargement du malware et a finalisé la redirection vers le faux nom de domaine.



02. Documentation de l'Incident

Vecteur d'Attaque & Compromission

Un ancien employé a profité d'une faille de configuration critique : le compte administratif du panneau de gestion de l'hébergeur possédait encore ses **identifiants par défaut**. En menant une attaque par force brute automatisée, l'acteur malveillant a rapidement validé le mot de passe d'usine.

Chronologie des Événements

1. **Accès & Persistance** : Authentification réussie sur le panneau d'administration. L'attaquant modifie immédiatement le mot de passe administrateur pour verrouiller les accès légitimes du propriétaire.
2. **Injection de Code** : Intégration d'une fonction JavaScript frauduleuse directement dans le code source de la page d'accueil de `yummyrecipesforme.com`.
3. **Découverte** : Plusieurs heures après, vagues de courriels de clients au support technique se plaignant de ralentissements système majeurs et d'invitations suspectes à installer un package pour obtenir des recettes gratuites.
4. **Analyse Sandbox** : Réplication de l'attaque par l'équipe SOC. Le flux de transactions confirme le schéma : Requête DNS → Requête HTTP → Exécution du fichier → Altération de la table DNS locale → Redirection automatique vers le domaine malveillant `greatrecipesforme.com`.

Preuves & Matériels d'Appui

- **Rapports Support** : Logs des courriels et plaintes des utilisateurs.
- **Analyse de Code** : Extraction et confirmation par l'analyste principal du script JavaScript injecté à l'insu de l'organisation.
- **Captures Réseau** : Séquences de paquets enregistrées par l'utilitaire de diagnostic réseau, corroborant les redirections DNS forcées.



Recommandation Prioritaire : Authentification Multi-Facteurs (MFA/2FA)

Pour neutraliser définitivement les attaques par force brute et sécuriser les accès d'administration, la mise en œuvre d'une politique stricte de durcissement est requise :

- **Obligation de double facteur (2FA) :** Tout accès au panneau d'administration devra requérir la validation d'un jeton à usage unique (TOTP) généré sur un terminal physique distinct. Même en cas de compromission du mot de passe, l'accès reste bloqué.
- **Suppression des comptes d'usine :** Modification obligatoire de tous les mots de passe par défaut dès l'initialisation des systèmes.
- **Limitation des tentatives :** Activation de règles de blocage (via des modules de type Fail2ban) pour bannir temporairement toute adresse IP échouant à plus de 3 tentatives d'authentification consécutives.